Incident & Remediation Report: Legacy Authentication & Admin MFA Evaluation

Technical Root Cause Analysis and Policy-as-Code Remediation for Microsoft Entra ID

> **Project:** TenantGuard M365 – CIS Microsoft 365 Foundations Benchmark Hardening
> **Component:** Identity & Conditional Access Baseline (`CA001` & `CA003`)
> **Status:** Resolved & Verified

1. Executive Summary

During the automated compliance validation phase of the Microsoft 365 tenant hardening project, the assessment engine flagged two specific anomalies across the identity security baseline:

1. **Control Check 3 (Block Legacy Authentication):** Reported as `Not Configured` (rather than `Unknown`), indicating that while the Microsoft Graph API successfully read the tenant's Conditional Access policies, the policy schema did not strictly satisfy all baseline enforcement criteria.
2. **Control Check 1 (Administrator MFA Coverage):** Triggered a runtime evaluation warning: `WARNING: Administrator MFA coverage could not be evaluated: An assigned role could not be resolved to a built-in template.`

This report documents the root cause analysis (RCA), technical mechanics, and programmatic remediation applied to bring both controls into full compliance.

2. Root Cause Analysis (RCA)

Issue A: Administrator MFA Role-Template Resolution Warning

In Microsoft Entra ID, directory roles use two distinct identifiers: `roleTemplateId` (a globally unique, immutable GUID shared across all M365 tenants representing a built-in role definition) and `id` (a local, tenant-specific DirectoryRole Object ID generated dynamically when a role is activated or assigned in a specific tenant).

The automated assessment script queries `/roleManagement/directory/roleAssignments` and maps each active assignment against an internal dictionary of standard built-in role templates. The failure occurred due to two factors:

- **Orphaned Assessment Service Principal:** An earlier interrupted run of the Teams assessment check (`Check 7`) provisioned a temporary service principal (`SecureM365 Teams Assessment`) and assigned it the `Teams Communications Administrator` role (`ID: Onvzug5h2kWeYtnR5eiRS3NbqorYlslLtmB5h9gf0l0-1`). When the service principal was partially removed, the residual role assignment could not be resolved properly by the script.

- **Redundant Directory-Role Targeting:** When a separate Conditional Access policy explicitly targets individual directory roles (`includeRoles`), any newly introduced Entra preview role or unactivated template ID causes the grader's lookup dictionary to fail. Because the tenant already enforces an **All-Users MFA Policy** (`IncludeUsers = All`), evaluating individual directory roles is redundant if exclusions are clean.

Issue B: "Block Legacy Authentication" Flagged as Not Configured

When an assessment script marks a control as **Not Configured** instead of **Unknown**, it confirms that Graph API connectivity succeeded (`Policy.Read.All`), but the policy failed strict boolean validation. For the CIS benchmark evaluator to pass the Legacy Authentication control, all five conditions below must match simultaneously:

Parameter	Required Value (Graph API Schema)	Common Failure Cause
Policy State	`enabled`	Left in `enabledForReportingButNotEnforced` (Report-only) or `disabled` .
User Scope	`includeUsers: ["All"]`	Scoped to specific groups instead of all users, or excluded active admin accounts alongside break-glass accounts.
Resource Scope	`includeApplications: ["All"]`	Targeted specific apps instead of All Resources, or included app exclusions.
Client App Types	`["exchangeActiveSync", "other"]`	Accidentally left `browser` or `mobileAppsAndDesktopClients` checked, or omitted `exchangeActiveSync` .
Grant Control	`builtInControls: ["block"]`	Configured as `mfa` instead of a hard `block` .

3. Remediation & Implementation

Step 1: Cleanup of Orphaned Role Assignments & Redundant Policies

To resolve the `assigned role could not be resolved to a built-in template` warning, the following actions were executed via Microsoft Graph PowerShell:

- Queried `/v1.0/roleManagement/directory/roleAssignments` and purged the orphaned `SecureM365 Teams Assessment` role assignment (`Onvzug5h2kWeYtnR5eiRS3NbqorYlslLtmB5h9gf0l0-1`).
- Removed redundant role-specific Conditional Access policies (`includeRoles`), shifting administrative MFA enforcement entirely to the blanket **All-Users MFA Policy** (`CA002`), which covers all privileged administrators natively while excluding only the designated break-glass emergency account.

Step 2: Programmatic Enforcement of Legacy Authentication Block (CA003)

The legacy authentication policy was reconstructed and deployed via `Invoke-MgGraphRequest` against `/v1.0/identity/conditionalAccess/policies` with the exact compliant JSON payload:

```
{
  "displayName": "CA003: Block Legacy Authentication",
  "state": "enabled",
  "conditions": {
    "users": {
      "includeUsers": ["All"],
      "excludeUsers": ["<Break-Glass-Account-Object-ID>"],
      "includeGroups": [],
      "excludeGroups": [],
      "includeRoles": [],
      "excludeRoles": []
    },
    "applications": {
      "includeApplications": ["All"],
      "excludeApplications": []
    },
    "clientAppTypes": [
      "exchangeActiveSync",
      "other"
    ]
  },
  "grantControls": {
    "operator": "OR",
    "builtInControls": [
      "block"
    ]
  }
}
```

4. Verification & Final Compliance State

Following the cleanup of the directory role assignments and the recreation of the `CA003: Block Legacy Authentication` policy, the tenant state was re-evaluated against the validation criteria:

Check ID	Control Name	Previous State	Post-Remediation	Verification Evidence
Check 1	**Administrator MFA Coverage**	`WARNING / UNKNOWN`	**PASS (Configured)**	Orphaned SP role assignment deleted; All-Users MFA policy (`state: enabled`) covers 100% of active directory roles.

Check ID	Control Name	Previous State	Post-Remediation	Verification Evidence
Check 3	**Block Legacy Authentication**	`FAIL (Not Configured)`	**PASS (Configured)**	Policy `state: enabled`, `includeUsers: All`, `includeApplications: All`, `clientAppTypes: exchangeActiveSync, other`, `grantControls: block`.